

Python Web Security Scanner + Hardening Assistant

A focused roadmap for building a v1 scanner first, then layering on reporting, hardening guidance, and tests.

Resource Stack

HTTPX docs: <https://www.python-httpx.org/>

Beautiful Soup docs: <https://www.crummy.com/software/BeautifulSoup/bs4/doc/>

urllib.parse docs: <https://docs.python.org/3/library/urllib.parse.html>

ssl docs: <https://docs.python.org/3/library/ssl.html>

Typer docs: <https://typer.tiangolo.com/>

Rich docs: <https://rich.readthedocs.io/>

Pydantic docs: <https://docs.pydantic.dev/>

Jinja docs: <https://jinja.palletsprojects.com/>

pytest docs: <https://docs.pytest.org/>

More References

OWASP WSTG: <https://owasp.org/www-project-web-security-testing-guide/>

OWASP HTTP Headers Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Headers_Cheat_Sheet.html

OWASP HSTS Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html

Apache security tips: https://httpd.apache.org/docs/2.4/en/misc/security_tips.html

Apache mod_headers: https://httpd.apache.org/docs/current/en/mod/mod_headers.html

Roadmap

- Phase 1: HTTPX and urllib.parse for fetching pages, handling redirects, headers, cookies, status codes, and URL normalization.
- Phase 2: BeautifulSoup for crawling links, forms, scripts, images, and page structure.
- Phase 3: ssl and socket for certificate expiry, TLS basics, and hostname verification.
- Phase 4: Pydantic for findings, scan results, and configuration models.
- Phase 5: Typer and Rich for a clean CLI with tables, progress bars, and severity labels.
- Phase 6: JSON and Jinja2 for machine-readable exports and HTML reports.
- Phase 7: pytest for regression coverage and confidence as the scanner grows.

Practice Targets

NGINX security controls: <https://docs.nginx.com/nginx/admin-guide/security-controls/>

OWASP Juice Shop: <https://owasp.org/www-project-juice-shop>

DVWA: <https://www.dvwa.co.uk/>

What to Focus on First

HTTP and HTTPS basics, security headers, cookies and session security, CORS, TLS and SSL basics, redirects, directory listing, exposed sensitive files, dangerous HTTP methods, server information disclosure, and WAF signals.

What to Skip for v1

Skip ML features, AI features, advanced exploitation, malware analysis, Kubernetes, cloud security, async scanning, and a full database system until the core scanner is stable.